

Diagnóstico de uso de inteligencia artificial en la organización

Metodología, instrumentos y formato de informe

Versión 1.0 · Borrador para prueba piloto · Octubre de 2026

Documento de trabajo de la empresa consultora. El autodiagnóstico (sección 6) y el cuestionario para jefaturas (7.1) se entregan al cliente; el resto es para el equipo que realiza el diagnóstico. El diagnóstico aplica los Elementos 1 y 2 del EC-B (inventario y evaluación de riesgos) a una organización real.

1. Qué es y qué no es

Qué es. Un servicio de consultoría de 2 a 4 semanas con el que la organización sabe:

1. Qué sistemas de IA usa, incluidos los no autorizados y las funciones de IA que vienen dentro de otro software.
2. Qué riesgos corre con cada uso: datos personales, seguridad de la información, exactitud, sesgo, derechos de las personas trabajadoras, imagen y voz, y continuidad.
3. Qué obligaciones vigentes se relacionan con esos usos.
4. Qué hacer primero, en una hoja de ruta de 90 días.

Qué no es.

- No es una opinión jurídica. Las obligaciones legales se señalan para que el área jurídica del cliente o un abogado externo las confirme.
- No es una auditoría de seguridad: no incluye pruebas de penetración ni revisión de código.
- No es una certificación. La certificación de personas se obtiene con la evaluación en el EC-A o el EC-B.

Marco de referencia. EC-B (Elementos 1 y 2); NIST AI RMF 1.0 (funciones de mapear y medir); ISO/IEC 42001 (contexto, evaluación de riesgos y de impacto); ISO/IEC 23894 (gestión de riesgos de IA).

2. Modalidades

Modalidad	Para quién	Duración	Qué incluye	Entregable
Autodiagnóstico exprés	Cualquier organización; primer contacto comercial	15 minutos de la dirección y una reunión de 30 minutos	Cuestionario de 20 preguntas (sección 6) y reunión de resultados	Puntaje, semáforo y tres recomendaciones
Diagnóstico estándar	Hasta 250 personas, una sede	2 semanas	Cuestionario a jefaturas, 6 a 8 entrevistas, revisión de contratos y licencias, registro técnico agregado	Informe de diagnóstico y presentación a la dirección
Diagnóstico ampliado	Más de 250 personas, varias sedes o sectores regulados	3 a 4 semanas	Lo del estándar, con 10 a 16 entrevistas, revisión por sede y evaluación de impacto de un uso de riesgo alto	Informe, evaluación de impacto y presentación a la dirección

Variables para cotizar: número de personas, de áreas y de sedes; número de sistemas contratados; sector; si se requiere evaluación de impacto; si el cliente pide revisión jurídica externa. *Los precios se definen por separado.*

3. Alcance, exclusiones y supuestos

Incluye: las actividades de la modalidad contratada, el informe y una presentación a la dirección.

Excluye: opinión jurídica, pruebas técnicas de seguridad, implementación de controles, redacción de contratos y capacitación. Estos servicios se cotizan aparte.

Contrato. El servicio se formaliza con el contrato de prestación de servicios profesionales del documento 20 (alcance, entregables, exclusión de opinión jurídica, límite de responsabilidad, confidencialidad y, si el cliente entrega datos personales, contrato de encargo).

Supuestos:

- El cliente designa una persona enlace con autoridad para convocar a las áreas.
- El cliente entrega los insumos de la sección 5 en los primeros tres días hábiles.
- Tecnologías de la Información del cliente extrae el registro técnico agregado; el equipo consultor no accede a los sistemas del cliente.

4. Fases del diagnóstico estándar

Fase	Días hábiles	Actividades	Producto intermedio
0. Arranque	1	Reunión con la dirección; firma del contrato de servicios y del convenio de confidencialidad; designación del enlace; entrega de la solicitud de insumos y del cuestionario a jefaturas	Calendario de entrevistas
1. Levantamiento	2 a 6	Cuestionario a jefaturas; entrevistas; revisión de contratos, licencias y condiciones de servicio; recepción del registro técnico	Inventario preliminar
2. Análisis	7 a 9	Integración del inventario con las tres fuentes; escala y matriz de riesgos; revisión de obligaciones; índice de madurez; hoja de ruta	Borrador del informe
3. Cierre	10	Presentación a la dirección; entrega del informe; acuerdo de siguientes pasos	Informe final

En el diagnóstico ampliado, la fase 1 dura de 8 a 12 días y se agrega la evaluación de impacto en la fase 2.

5. Insumos que se solicitan al cliente

Insumo	Para qué se usa	¿Obligatorio?
Organigrama y relación de jefaturas	Definir a quién se entrevista	Sí
Relación de contratos y licencias de software, con las funciones de IA que anuncia cada proveedor	Identificar sistemas contratados y funciones incorporadas	Sí

Insumo	Para qué se usa	¿Obliga torio?
Condiciones de servicio o contratos de los proveedores de IA	Aplicar la lista de verificación de proveedores	Sí
Registro técnico agregado: servicios de IA accedidos desde la red y los equipos, por área y número de accesos, sin contenido ni identificación de personas	Identificar usos no reportados	Sí
Política de seguridad de la información y esquema de clasificación	Valorar riesgos conforme a la clasificación del cliente	Sí, si existen
Aviso o avisos de privacidad	Revisar si informan los usos de IA	Sí
Política de uso de IA, si existe	Revisar su contenido	Sí existe
Registro de incidentes de seguridad del último año	Identificar incidentes relacionados con IA	Sí existe
Programa de capacitación y registros de DC-3	Revisar la capacitación en el uso de IA	Sí existe

Solicitud a Tecnologías de la Información. Se pide un resumen del último mes con: servicios de IA generativa (asistentes de texto, transcriptores, generadores de imagen, voz o video), extensiones de navegador y aplicaciones con funciones de IA, y llamadas a interfaces de programación de servicios de IA. Para cada uno: tipo de cuenta (institucional o personal, si se puede distinguir), área de origen y número de accesos. **No se solicita el contenido de las conversaciones ni la identidad de las personas.**

6. Autodiagnóstico exprés para la dirección

Se entrega al cliente. Responder con base en lo que la organización puede demostrar, no en lo que se supone.

Puntaje: **Sí = 2, Parcial = 1, No / no sé = 0.**

#	Pregunta	S í	Parc ial	No / no sé
A. Inventario y visibilidad				
1	¿La organización tiene una lista actualizada de las herramientas y sistemas de IA que usa, incluidas las funciones de IA dentro de otro software?			
2	¿Sabe si el personal usa cuentas personales de herramientas de IA para tareas de trabajo?			
3	¿Tecnologías de la Información puede ver qué servicios de IA se usan desde la red y los equipos?			
4	¿Cada sistema de IA en uso tiene una persona responsable designada?			
B. Riesgos y decisiones sobre personas				
5	¿Se han evaluado los riesgos de los usos de IA (datos personales, seguridad, exactitud, sesgo, derechos de las personas trabajadoras, imagen y voz, continuidad)?			
6	¿Toda decisión sobre candidatos, trabajadores o clientes que se apoya en IA pasa por la revisión de una persona antes de producir efectos?			
7	¿Se hizo una evaluación de impacto antes de usar IA en decisiones que afectan a personas?			

#	Pregunta	S í	Parc ial	No / no sé
8	¿El aviso de privacidad informa los usos de IA que tratan datos personales?			
C. Política y controles				
9	¿Existe una política de uso de IA aprobada por la dirección?			
10	¿La política indica qué información puede y no puede ingresarse a las herramientas de IA?			
11	¿Hay un procedimiento para autorizar nuevas herramientas o módulos de IA antes de usarlos?			
12	¿Las herramientas de IA no autorizadas se bloquean o se controlan técnicamente?			
D. Proveedores y terceros				
13	¿Antes de contratar se revisan las condiciones de los proveedores de IA sobre el uso de la información para entrenamiento, la conservación, la ubicación y la eliminación?			
14	¿Los contratos con proveedores de IA fijan un plazo para que notifiquen los incidentes de seguridad?			
15	¿Se sabe qué proveedores de IA reciben datos personales y si los tratan por cuenta de la organización o para fines propios?			
16	¿Se pide consentimiento por escrito para usar la imagen o la voz de personas en contenido generado con IA, y se etiqueta ese contenido?			
E. Personas, capacitación e incidentes				
17	¿El personal que usa IA recibió capacitación sobre la política, la protección de la información y la verificación de resultados, con registro (por ejemplo, constancias DC-3)?			
18	¿El personal sabe reconocer y reportar una suplantación con voz, imagen o video falsos?			
19	¿Existe un procedimiento para atender incidentes de IA, incluida la determinación de informar a las personas titulares de los datos?			
20	¿La dirección recibe un informe periódico sobre el uso y los riesgos de la IA?			

Resultado

Puntaje total (0 a 40)	Semáforo	Lectura
0 a 14	Rojo	La IA se usa sin control suficiente. Hay exposición actual en datos personales, seguridad o decisiones sobre personas. Se recomienda el diagnóstico estándar o ampliado
15 a 29	Amarillo	Hay medidas parciales. Se recomienda el diagnóstico para cerrar brechas y priorizar
30 a 40	Verde	Hay una base de gestión. Se recomienda verificar que los controles funcionan y certificar al personal clave

Alertas inmediatas. Sin importar el puntaje, si la respuesta a la pregunta 2, 6 o 12 es "No / no sé", se recomienda actuar de inmediato: revisión humana de las decisiones sobre personas y control de herramientas no autorizadas.

Puntaje por dimensión (0 a 8, suma de sus cuatro preguntas): de 0 a 2, Inicial; de 3 a 4, Básico; de 5 a 6, Gestionado; de 7 a 8, Integrado (ver sección 8).

7. Instrumentos del diagnóstico estándar

7.1 Cuestionario de levantamiento para jefaturas

Dirigido a: titulares de cada área.

Instrucciones para el llenado: Este cuestionario sirve para integrar el inventario de los sistemas de inteligencia artificial que usa la organización. No es una auditoría para sancionar: el objetivo es conocer los usos y apoyar a las áreas para usarlos con seguridad. Responda por cada herramienta, sistema o función de IA que use su área, incluidas las cuentas personales, las extensiones de navegador y las funciones de IA que vienen dentro de otros programas (correo, procesador de textos, nómina, sistemas de gestión). Entregue el cuestionario a [enlace] a más tardar el [fecha].

Pregunta	Respuesta
Nombre de la herramienta, sistema o función, y proveedor	
¿Cómo se accede? (cuenta institucional, cuenta personal, integrada en otro sistema, extensión o aplicación)	
¿Para qué se usa y en qué proceso?	
¿Con qué frecuencia? (diaria, semanal, ocasional)	
¿Cuántas personas del área la usan?	
¿Qué información se ingresa? (pública, interna, confidencial, datos personales, datos personales sensibles) Describa un ejemplo	
¿El resultado se usa para decidir algo sobre personas (candidatos, trabajadores, clientes)? ¿Qué decisión?	
¿Alguien revisa el resultado antes de usarlo? ¿Quién?	
¿Quién autorizó su uso?	

Pregunta final: "¿Algún sistema que usen da puntuaciones, predicciones o recomendaciones sobre personas?"

7.2 Guía de entrevista

Apertura (2 minutos). Presentarse; explicar el propósito del inventario, el uso de la información y que no es una auditoría para sancionar; dar a conocer el aviso de privacidad simplificado de la empresa consultora para personas entrevistadas (documento 19); pedir permiso para tomar notas.

Preguntas por tareas (10 minutos).

1. ¿Cuáles son las tareas del área que más tiempo toman?
2. ¿Cómo preparan sus reportes, correos, presentaciones o análisis?
3. ¿Usan alguna herramienta que redacte, resuma, traduzca, transcriba, clasifique, prediga o recomiende?

Preguntas por sistemas (10 minutos).

4. ¿Los sistemas que ya usan (correo, nómina, gestión, atención a clientes) traen funciones de IA? ¿Las activaron?
5. ¿Alguien usa cuentas personales, aplicaciones del celular o extensiones del navegador para estas tareas?
6. ¿Qué información se ingresa? ¿Incluye datos de personas? ¿Datos de salud, financieros o de terceros?

Preguntas por decisiones (5 minutos).

7. ¿Qué decisiones se toman con esos resultados? ¿Afectan a candidatos, trabajadores o clientes?

8. ¿Alguien revisa el resultado antes de que produzca efectos? ¿Qué pasa si la persona afectada no está de acuerdo?

Cierre (3 minutos). Leer lo registrado y pedir que se confirme o corrija; agradecer; explicar los siguientes pasos.

7.3 Lista de verificación de proveedores de IA

Criterio	Pregunta	Resultado (cumple / no cumple / no se sabe)
Uso de la información	¿El proveedor usa la información ingresada para entrenar sus modelos o para fines propios? ¿Puede excluirse por escrito?	
Calidad del proveedor	¿Actúa solo por cuenta de la organización y conforme a sus instrucciones, con contrato (persona encargada), o usa los datos para fines propios (tercero, con transferencia)?	
Conservación	¿Por cuánto tiempo conserva la información? ¿Es acorde con la finalidad?	
Ubicación	¿Dónde se almacena? ¿Hay transferencias a otros países? ¿Con qué fundamento?	
Eliminación	¿Elimina o devuelve la información al terminar el contrato, con constancia y en un plazo definido?	
Confidencialidad y seguridad	¿Qué medidas concretas aplica? ¿Tiene certificaciones vigentes y con qué alcance?	
Notificación de incidentes	¿En qué plazo avisa a la organización de un incidente?	
Terceros	¿Comparte información, incluso agregada, con otras empresas?	
Recomendación	Autorizar, autorizar con condiciones o no autorizar, con su fundamento	

7.4 Escala de valoración de riesgos

Se usa la escala de 3 × 3 de la Guía de estudio del EC-B (documento 12, Unidad 2, apartado 2.2), salvo que el cliente tenga una metodología de riesgos propia; en ese caso se usa la del cliente, para que los resultados se integren a su gestión de riesgos.

8. Índice de madurez

Dimensión	1. Inicial	2. Básico	3. Gestionado	4. Integrado
A. Inventario y visibilidad	No hay inventario; no se sabe qué IA se usa	Lista parcial de lo contratado	Inventario con las tres fuentes y responsables	Inventario actualizado con cada alta y revisado periódicamente
B. Riesgos y decisiones sobre personas	Sin evaluación; decisiones automatizadas sin revisión	Evaluación informal de algunos usos	Matriz de riesgos; revisión humana en decisiones sobre personas; evaluación de impacto de los usos de riesgo alto	Riesgos revisados periódicamente y ligados a la gestión de riesgos de la organización

Dimensión	1. Inicial	2. Básico	3. Gestionado	4. Integrado
C. Política y controles	Sin política; uso libre	Reglas informales o comunicados	Política aprobada, procedimiento de autorización y controles técnicos	Controles verificados periódicamente y mejorados
D. Proveedores y terceros	No se revisan condiciones	Revisión ocasional	Lista de verificación antes de contratar; cláusulas de notificación y eliminación	Proveedores revisados periódicamente; contratos con cláusulas tipo
E. Personas, capacitación e incidentes	Sin capacitación ni procedimiento	Pláticas sin registro	Capacitación con registro; procedimiento de incidentes; informe a la dirección	Personal clave certificado (EC-A y EC-B); simulacros de incidentes

9. Formato del informe de diagnóstico

- 1. Resumen para la dirección** (una página): semáforo e índice de madurez por dimensión; los cinco hallazgos principales; las decisiones que se requieren de la dirección.
- 2. Inventario de sistemas de IA**, con la fuente de cada sistema y su condición.
- 3. Matriz de riesgos** y detalle de los riesgos altos.
- 4. Obligaciones relacionadas** (análisis de cumplimiento, no opinión jurídica):
 - **Protección de datos personales** (Ley Federal de Protección de Datos Personales en Posesión de los Particulares, DOF 20 de marzo de 2025, última reforma DOF 14 de noviembre de 2025): medidas de seguridad (art. 18), aviso de privacidad (arts. 14 a 16), comunicación a personas encargadas y transferencias a proveedores de IA (arts. 2 y 35), datos sensibles (art. 8), oposición a decisiones automatizadas (art. 26) y atención de vulneraciones (art. 19).
 - **Laborales** (Ley Federal del Trabajo): obligación de capacitar y su registro (arts. 153-A, 153-T y 153-V); no discriminación (art. 133); supervisión en teletrabajo (art. 330-I); sanciones conforme al reglamento interior de trabajo (art. 423); usos de IA en selección, evaluación, supervisión y terminación.
 - **Contractuales**: condiciones de los proveedores de IA; obligaciones con clientes cuyos datos trata la organización.
 - **Imagen, voz y obras de terceros**: Ley Federal del Derecho de Autor (incluida la protección de la imagen y la voz de artistas frente a la IA, art. 87, reforma de mayo de 2026), Ley Federal de Protección a la Propiedad Industrial (marcas y secretos industriales) y Código Civil Federal (daño moral, art. 1916).
- 5. Revisión de proveedores** con la lista de verificación.
- 6. Hoja de ruta de 90 días**:
 - **Días 1 a 30, contención**: revisión humana de las decisiones sobre personas; bloqueo o control de herramientas no autorizadas; política provisional (puede partir de la plantilla, documento 14); aviso al personal sobre qué no ingresar.
 - **Días 31 a 60, formalización**: política aprobada; procedimiento de autorización; convenios con proveedores; capacitación del personal usuario (contenidos del EC-A).
 - **Días 61 a 90, gestión**: responsable de gobernanza de IA designado y capacitado (contenidos del EC-B); programa de verificación de controles; primer informe a la dirección.
- 7. Anexos**: cuestionarios, relación de entrevistas, listas de verificación aplicadas.

10. Equipo, confidencialidad y tratamiento de datos

Equipo:

- **Consultor líder:** experiencia en gestión de riesgos, protección de datos personales o seguridad de la información; certificado en el EC-B cuando se publique.
- **Consultor de apoyo:** realiza entrevistas y revisión documental.
- **Revisión jurídica externa** (opcional, a solicitud del cliente).

Confidencialidad y datos:

- Antes de iniciar se firma un convenio de confidencialidad.
- El equipo consultor no solicita datos personales de clientes ni de trabajadores del cliente. Solo recibe los datos de contacto de las personas entrevistadas y documentos sin datos personales o con ellos depurados. Los datos de contacto y las notas de las entrevistas los trata la empresa consultora como responsable, conforme a su aviso de privacidad para personas entrevistadas (documento 19).
- Si para alguna actividad el cliente debe entregar datos personales, la empresa consultora actúa como persona encargada y se firma el contrato de encargo del documento 20: instrucciones, finalidad limitada, medidas de seguridad, confidencialidad, aviso de vulneraciones, subcontratación solo autorizada y devolución o supresión al terminar. Si la consultora usara esos datos para fines propios, asumiría el carácter de responsable (Reglamento de 2011, artículo 53; aplicación por confirmar).
- Los documentos del cliente se conservan solo durante el servicio y se eliminan o devuelven al cierre, con constancia.
- El equipo consultor aplica su propia política de uso de IA: no ingresa información del cliente a herramientas de IA no autorizadas por el cliente.

11. Relación con el resto de la oferta

Hallazgo frecuente	Servicio que lo atiende
Sin política de uso de IA	Adaptación de la plantilla de política (documento 14)
Personal que usa IA sin capacitación	Curso de alineación del EC-A (documento 09), con DC-3, y certificación en el EC-A
Sin responsable de gobernanza de IA	Curso de alineación del EC-B (documento 11) y certificación en el EC-B
Proveedores sin cláusulas	Revisión de contratos con el área jurídica del cliente
Controles sin verificar	Servicio de seguimiento trimestral

Las recomendaciones del informe se basan en los hallazgos y no se condicionan a la contratación de otros servicios.

12. Mensajes comerciales

Se puede decir	No se debe decir
"El uso no controlado de IA ya expone a la organización: datos personales en herramientas públicas, decisiones sobre personas sin revisión, proveedores sin cláusulas."	"La certificación es obligatoria por ley."
"La ley de datos personales exige medidas de seguridad y atender las vulneraciones; la Ley Federal del Trabajo obliga a capacitar."	"Le evitamos multas" o "cumplimiento garantizado."
"El diagnóstico sigue el EC-B y marcos internacionales como el NIST AI RMF e ISO/IEC 42001."	"Cumple con la ley europea de IA" (aplica solo en ciertos casos, y el artículo 4 se flexibilizó en julio de 2026).
"Los certificados los emite el CONOCER."	"Nuestro diagnóstico certifica a la empresa."

13. Notas para la prueba piloto

No forman parte del servicio.

1. Aplicar el autodiagnóstico exprés a 10 organizaciones y el diagnóstico estándar a 2 o 3, de distintos tamaños y sectores.
2. Medir el tiempo real de cada fase y ajustar la duración y las variables para cotizar.
3. Calibrar los rangos del semáforo y del índice de madurez con los resultados.
4. Pedir al área jurídica de una organización piloto que revise la sección de obligaciones del informe.